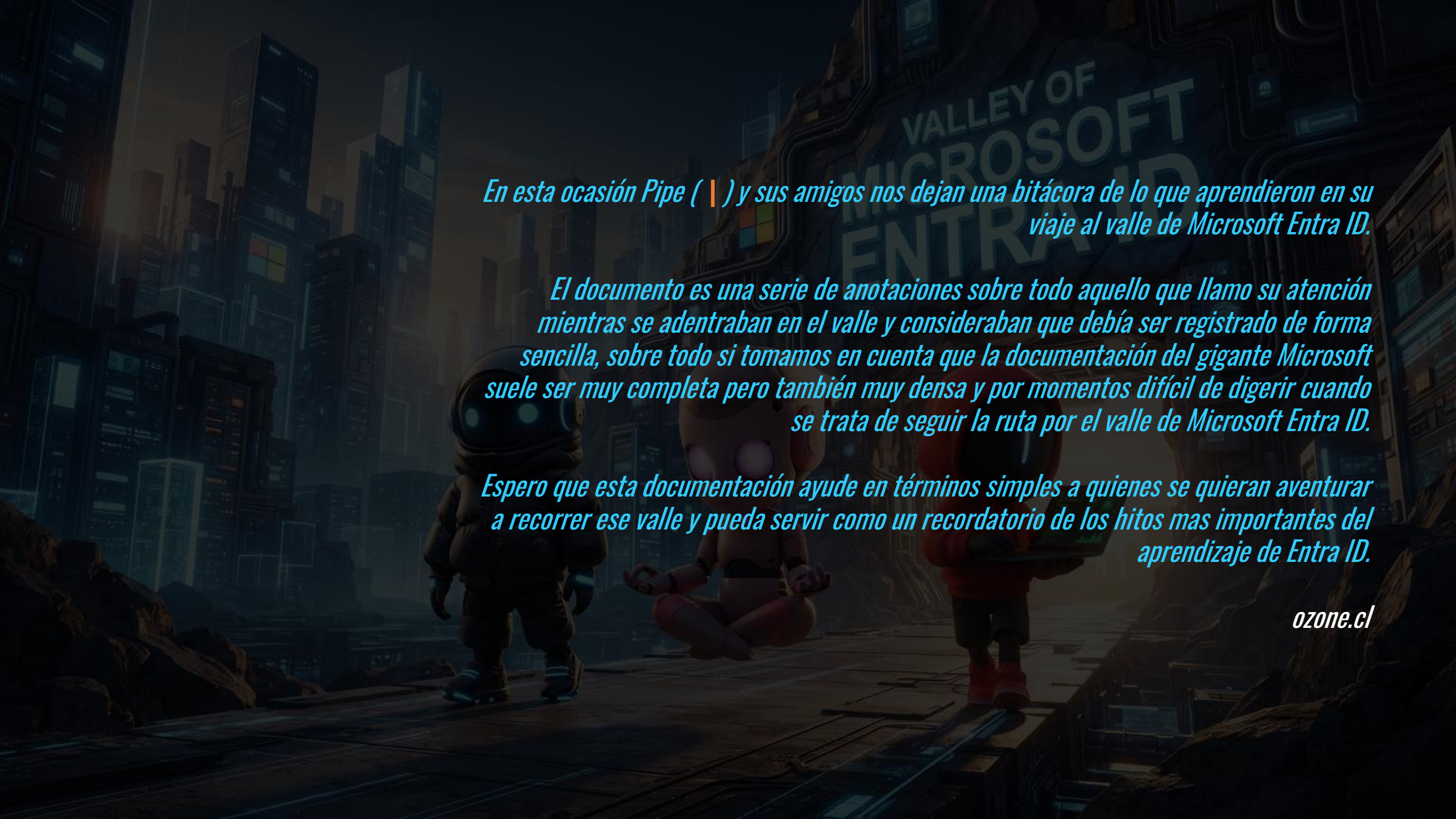


PIPE

EN EL VALLE DE
MICROSOFT
ENTRA ID

VALLEY OF
MICROSOFT
ENTRA ID





En esta ocasión Pipe (|) y sus amigos nos dejan una bitácora de lo que aprendieron en su viaje al valle de Microsoft Entra ID.

El documento es una serie de anotaciones sobre todo aquello que llamo su atención mientras se adentraban en el valle y consideraban que debía ser registrado de forma sencilla, sobre todo si tomamos en cuenta que la documentación del gigante Microsoft suele ser muy completa pero también muy densa y por momentos difícil de digerir cuando se trata de seguir la ruta por el valle de Microsoft Entra ID.

Espero que esta documentación ayude en términos simples a quienes se quieran aventurar a recorrer ese valle y pueda servir como un recordatorio de los hitos mas importantes del aprendizaje de Entra ID.

ozone.cl



Nexus Hub

Microsoft Entra
Identity Governance

Microsoft Entra
Permissions Management

Microsoft Entra
External ID

Microsoft Entra
Verified ID

Microsoft Entra
Secure Access

Microsoft
Entra ID

MICROSOFT ENTRA ID

¿QUÉ ES MICROSOFT ENTRA ID?



- *Es el servicio de Administración de identidad y acceso basado en la nube de Microsoft.*
- *Ayuda a las organizaciones a gestionar usuarios, grupos, aplicaciones y dispositivos en la nube.*
- *Proporciona inicio de sesión único (SSO) para aplicaciones en la nube y on premise.*
- *Protege el acceso con Acceso Condicional y MFA.*



MICROSOFT ENTRA ID AUTENTICACIÓN VS AUTORIZACIÓN



Autenticación vs. Autorización en Azure

Aunque suenan parecido, cumplen funciones totalmente distintas en la nube de Microsoft:

***Autenticación (AuthN)** – ¿Quién eres?: Es el proceso de verificar tu identidad. Azure comprueba que eres quien dices ser (mediante tu usuario, contraseña, MFA o SSO).*

***Autorización (AuthZ)** – ¿Qué puedes hacer?: Una vez que Azure sabe quién eres, este proceso determina a qué recursos específicos tienes acceso y qué permisos tienes sobre ellos.*

¿Cómo funcionan en Azure?

1. Autenticación (AuthN)

Se gestiona principalmente a través de Microsoft Entra ID (antiguamente Azure Active Directory).

- El mecanismo: Utiliza protocolos abiertos (como OpenID Connect y SAML) para emitir tokens de ID. Cuando inicias sesión con éxito, Azure le dice a la aplicación: "Sí, este usuario es efectivamente Juan Pérez".

2. Autorización (AuthZ)

*Se gestiona principalmente mediante Azure **RBAC** (Role-Based Access Control / Control de acceso basado en roles).*

*- El mecanismo: **Funciona asignando tres elementos: Quién** (el usuario autenticado), **Qué rol tiene** (ej. Lector, Colaborador, Propietario) y **Dónde se aplica** (el alcance, como una base de datos o toda la suscripción).*

- El resultado: Azure emite un token de acceso que le dice al sistema: "Juan Pérez tiene permitido modificar esta máquina virtual, pero no puede borrarla".



¿Qué es MFA?

MFA (Multi-Factor Authentication o Autenticación de Múltiples Factores) es un sistema de seguridad que requiere dos o más pruebas diferentes para verificar tu identidad antes de darte acceso a una cuenta. Su objetivo es simple: si un hacker te roba la contraseña, aún no podrá entrar porque le faltarán los otros factores.

¿Cómo funciona?

Funciona combinando elementos de tres categorías distintas:

- *Algo que sabes: Una contraseña, PIN o la respuesta a una pregunta secreta.*
- *Algo que tienes: Tu teléfono móvil (para recibir un SMS o usar una app de autenticación como Google Authenticator), una llave de seguridad física o un token.*
- *Algo que eres: Tu huella dactilar, reconocimiento facial o escaneo de retina (biometría).*

El proceso paso a paso:

- *Paso 1: Introduces tu usuario y contraseña habituales (Algo que sabes).*
- *Paso 2: El sistema te solicita la segunda prueba (ej. un código de 6 dígitos enviado a tu móvil o tu huella).*
- *Paso 3: Introduces ese código o escaneas tu huella (Algo que tienes / eres). Si coincide, accedes.*

¿Qué es SSO?

SSO (Single Sign-On o Inicio de Sesión Único) es un método de autenticación que te permite acceder a múltiples aplicaciones y servicios utilizando una sola cuenta y contraseña. Su objetivo principal es la comodidad y la eficiencia: te identificas una sola vez y el sistema te da "pase libre" para el resto de tus herramientas sin tener que iniciar sesión en cada una.

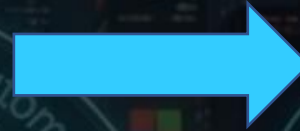
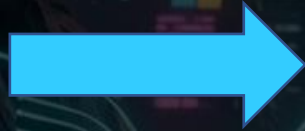
¿Cómo funciona?

Funciona bajo una relación de confianza mutua entre un Proveedor de Identidad (donde inicias sesión) y las aplicaciones. El proceso es el siguiente:

- *Paso 1: Intentas entrar a una aplicación (ej. Slack o Zoom).*
- *Paso 2: La aplicación, en lugar de pedirte contraseña, te redirige al portal de SSO de tu empresa o servicio (ej. Google, Microsoft u Okta).*
- *Paso 3: Introduces tus credenciales solo ahí.*
- *Paso 4: El proveedor de SSO verifica que eres tú y le envía un "token digital de confianza" a la aplicación.*
- *Paso 5: La aplicación recibe el token, comprueba que es válido y te deja entrar directamente.*

MICROSOFT ENTRA ID

SSO (INICIO DE SESIÓN ÚNICO)



- Los usuarios **HUMANOS** inician sesión una vez y acceden a múltiples aplicaciones.
- Soporta SAML, OAuth2.0, OpenID Connect.
- Reduce la fatiga de contraseñas y mejora la seguridad.
- Centraliza el control: Permite revocar el acceso a todas las aplicaciones al mismo tiempo desde un solo lugar.

USUARIO MIEMBRO

El empleado inicia sesión una sola vez en su computadora y entra directo a Outlook, Teams y al software de recursos humanos sin volver a poner su contraseña.

USUARIO INVITADO

Ana (la consultora externa) inicia sesión en el portal de su propia empresa. Cuando hace clic en el enlace del SharePoint de tu empresa, entra directo. El SSO "confía" en la sesión que ella ya inició en su organización externa.

IDENTIDAD EXTERNA

*Si tu empresa tiene varias páginas o aplicaciones para el público (por ejemplo, una tienda en línea y un foro de soporte), María se registra e inicia sesión **una sola vez**. Con esa misma sesión abierta, puede navegar entre ambas plataformas web de tu marca sin que se le vuelva a pedir su correo o cuenta de Google.*

Identities



Microsoft
Entra ID



Microsoft
Defender
for Identity

Endpoints



Mobile
Device



Microsoft
Defender



Microsoft
Endpoint
Manager

Continuous risk assessment & Automation

Zero Trust
policy enforcement



Microsoft
Conditional
Access

Threat intelligence & Telemetry

Applications



Microsoft
Defender
for Cloud

Microsoft
Information
Protection



Application



Microsoft
Information
Protection

Infrastructure



Microsoft
Cloud App
Security



Network

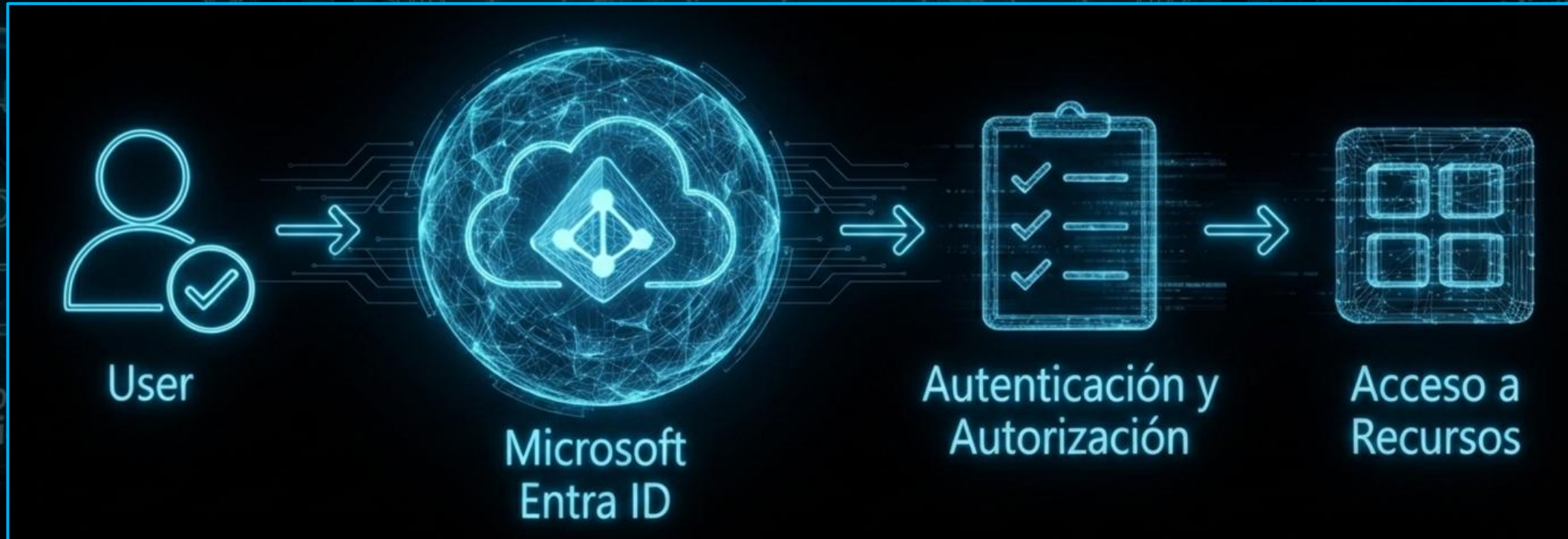


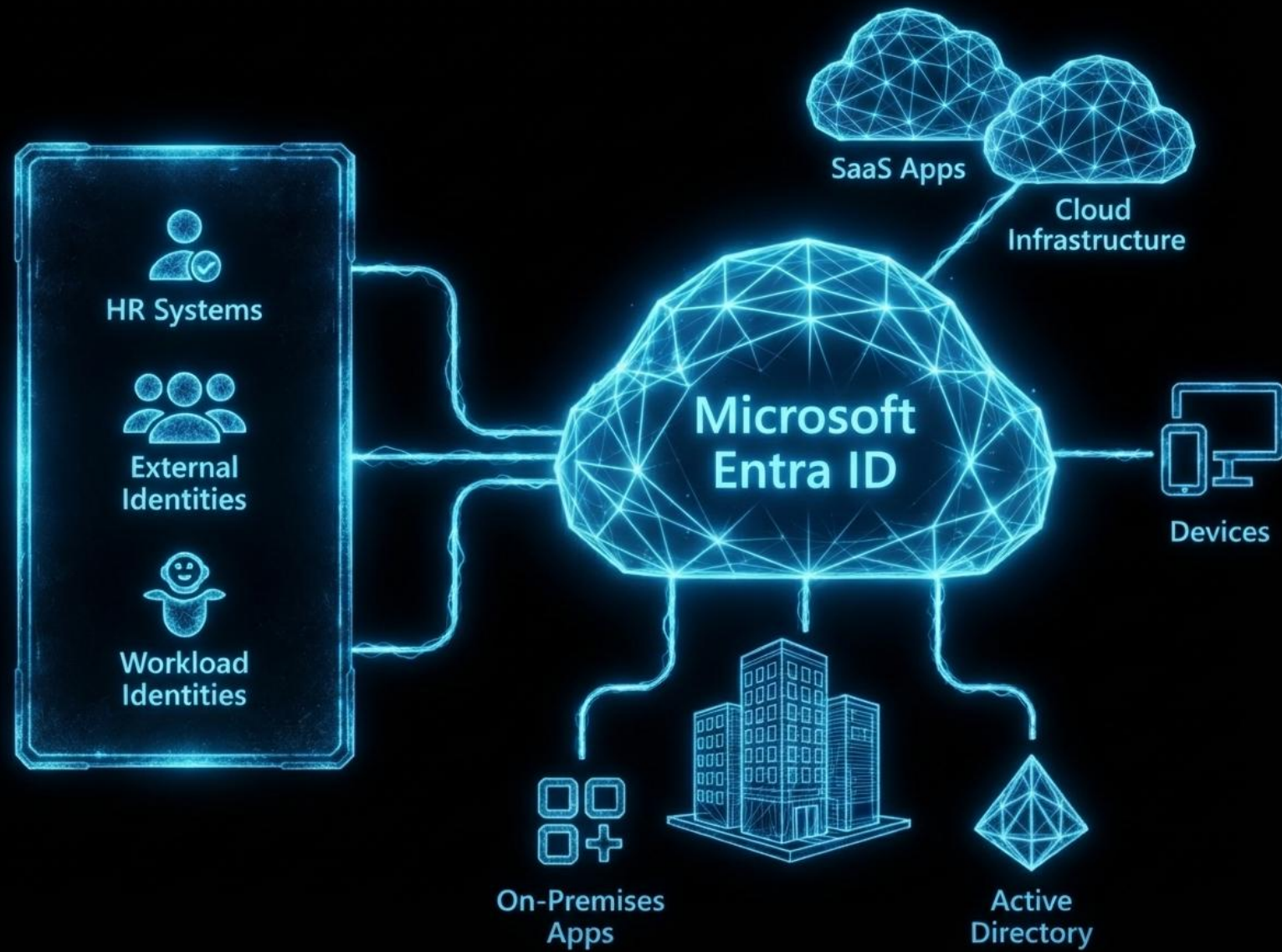
*1. El usuario **inicia sesión**.*

*2. Entra ID **identifica al usuario**.*

*3. Se **evalúan las políticas**.*

*4. Se **otorga acceso a los recursos**.*







MICROSOFT ENTRA ID

COMPONENTES PRINCIPALES



1. Tenant (Inquilino)

Es la instancia exclusiva y privada de Microsoft Entra ID en la nube.

Cómo funciona: Piensa en él como el edificio de tu empresa. Todo lo que crees (usuarios, grupos, etc.) vive dentro de este contenedor y está completamente aislado de otras empresas. Se genera automáticamente al crear una cuenta de Microsoft 365 o Azure.

2. Usuarios

Son las identidades individuales de las personas (o servicios) que necesitan acceder a los recursos.

Cómo funciona: Cada usuario tiene sus propias credenciales (correo y contraseña) y perfil. Pueden ser internos (empleados de la empresa) o invitados (clientes o proveedores externos a los que les das acceso limitado).

3. Grupos

Son colecciones de usuarios o dispositivos que se gestionan como una sola entidad para simplificar la administración.

Cómo funciona: En lugar de darle permisos a 50 personas una por una, creas un grupo llamado "Equipo de Ventas", les asignas el permiso al grupo, y automáticamente todos sus miembros lo heredan.

4. Dispositivos

Son los equipos físicos (ordenadores, portátiles, móviles) que registras en el sistema.

Cómo funciona: Entra ID los identifica para saber si el equipo desde el que intentas entrar es seguro y corporativo, o si es un teléfono personal desconocido, permitiendo aplicar reglas de Acceso Condicional basados en el estado del dispositivo.

5. Aplicaciones (Registros de aplicaciones / Enterprise Apps)

Son los software y servicios (tanto de Microsoft como externos: Salesforce, Zoom, apps propias) integrados con tu Entra ID.

Cómo funciona: Al conectar una aplicación a Entra ID, le delegas a este la responsabilidad de autenticar a los usuarios. Así, la app confía en Entra ID para dejar pasar a los usuarios mediante SSO.

MICROSOFT ENTRA ID

COMPONENTES PRINCIPALES



TENANT

Una instancia dedicada de Entra ID para una organización.



APLICACIONES

Aplicaciones empresariales y SaaS integradas con Entra ID.



USUARIOS

Identidades individuales que pueden iniciar sesión en Entra ID.



GRUPOS

Colección de usuarios para una gestión y acceso sencillos.



DISPOSITIVOS

Dispositivos registrados o unidos a Entra ID.



MICROSOFT ENTRA ID

TIPOS DE IDENTIDADES



1. Usuario Miembro (Member User)

Es el usuario interno y nativo de tu organización (normalmente un empleado).

Cómo funciona: Su cuenta se crea y se gestiona directamente dentro de tu Tenant. Por defecto, tiene permisos completos para ver el directorio (buscar a otros compañeros, ver grupos, etc.).

*Ejemplo: Carlos, un **empleado contratado** por tu empresa que tiene su correo corporativo (carlos@tuempresa.com) para trabajar todos los días.*

2. Usuario Invitado (Guest User)

Es un usuario externo (un colaborador, proveedor o consultor) al que invitas a tu entorno.

Cómo funciona: No creas una contraseña para él; se autentica usando las credenciales de su propia empresa o su correo personal. Por defecto, tiene permisos muy restringidos en tu directorio (no puede cotillear la lista de otros empleados).

*Ejemplo: Ana, una **consultora externa** de otra empresa que necesita entrar temporalmente a tu canal de Microsoft Teams para revisar un proyecto contigo.*

3. Identidades Externas (External Identities)

Es el paraguas tecnológico (llamado Microsoft Entra External ID) que gestiona cómo se conectan las personas de fuera de tu empresa.

Cómo funciona: Incluye tanto a los Usuarios Invitados (B2B, para colaborar en proyectos internos) como a Clientes (CIAM / B2C, personas externas que se registran en una aplicación que tú programaste usando su cuenta de Google, Facebook o Apple).

*Ejemplo: María, una **cliente** que se descarga la app móvil de tu tienda y se registra con su cuenta de Google para comprar un producto.*

4. Identidad Administrada (Managed Identity)

Es una identidad automática creada para recursos de código o sistemas (como una Máquina Virtual o una Azure Function), no para humanos.

Cómo funciona: Elimina la necesidad de que los desarrolladores guarden contraseñas o claves secretas en el código. El recurso de Azure se autentica directamente contra Entra ID de forma segura para consumir bases de datos u otros servicios.

*Ejemplo: Una **aplicación web o base de datos** en Azure que necesita conectarse automáticamente con otro servicio sin que un humano tenga que escribir o gestionar una contraseña.*



5. Identidades de carga de trabajo / Aplicaciones (Workload Identities)

Identidades para aplicaciones de software, scripts o contenedores externos a Azure que necesitan autenticarse. Se crean mediante los Service Principals (Principales de Servicio).

Diferencia con las Administradas: Las Administradas son exclusivas para recursos que viven dentro de Azure; las de carga de trabajo sirven para cualquier software (incluso fuera de Azure).

Ejemplo: Un **script automatizado** que corre en un servidor local de tu oficina (On-Premises) o en un contenedor de AWS, y que necesita conectarse de forma segura a Microsoft Entra ID para extraer informes o gestionar datos de los usuarios de tu empresa.

6. Identidades de Dispositivo (Device Identities)

El registro de los ordenadores y móviles en el directorio (ya sea como Entra Registered o Entra Joined). Entra ID los trata como identidades independientes para decidir si el equipo es seguro antes de dejarlo pasar.

Ejemplo: La **computadora portátil corporativa** que usa Carlos. El sistema la reconoce como un dispositivo "cumplidor" (Compliant), permitiéndole acceder a datos confidenciales porque sabe que tiene el antivirus activo y el disco cifrado.

7. Identidades de Agente de IA (Agent Identities)

Una categoría diseñada específicamente para Agentes de IA autónomos (Microsoft Entra Agent ID).

Cómo funciona: En lugar de camuflar un Bot de IA como si fuera un usuario humano o una aplicación genérica, se le asigna una identidad propia de agente. Esto permite auditar exactamente qué hace la IA, limitar sus acciones con el principio de mínimo privilegio y saber qué humano es su "padrino" responsable en caso de fallos.

Ejemplo: Un copiloto o **bot de IA** avanzado configurado para revisar facturas automáticamente. El agente tiene su propia identidad registrada para poder auditar qué documentos modificó y asegurar que solo acceda a la carpeta de contabilidad y no a la de recursos humanos.

MICROSOFT ENTRA ID

TIPOS DE IDENTIDADES



USUARIO MIEMBRO

Creado y gestionado dentro de Entra ID.

USUARIO INVITADO

*Colaboradores externos invitados **con** acceso a herramientas internas.*

IDENTIDADES EXTERNAS

*Clientes o socios utilizando CIAM (Customer Identity and Access Management) **sin** acceso al entorno interno.*

IDENTIDAD ADMINISTRADA

Utilizada por servicios y aplicaciones de Azure.

IDENTIDADES DE CARGA DE TRABAJO

Utilizada por aplicaciones, scripts o contenedores externos a Azure.

IDENTIDAD DE DISPOSITIVO

El registro de los equipos físicos para validar su seguridad.

IDENTIDAD DE AGENTE DE IA

Diseñada específicamente para agentes de IA autónomos.



1. Password (Contraseña)

El método tradicional basado en una cadena de texto secreta.

Cómo funciona: El usuario memoriza una clave y la introduce al iniciar sesión. Es el método más común, pero también el más vulnerable a hackeos, phishing y descuidos.

2. Basada en Certificados (CBA)

Autenticación mediante un archivo digital seguro (certificado) guardado en tu equipo o tarjeta inteligente.

Cómo funciona: El sistema del navegador o dispositivo intercambia este certificado criptográfico directamente con Entra ID. No requiere que escribas nada; si el certificado es válido y confiable, entras automáticamente.

3. FIDO2 (Llaves de seguridad)

El estándar físico y digital más seguro del mercado, resistente al phishing por diseño.

Cómo funciona: Utilizas un dispositivo físico (como una llave USB YubiKey) o la biometría de tu ordenador (Windows Hello / Touch ID). Al iniciar sesión, tocas la llave o pones tu huella; la llave firma criptográficamente el acceso de forma única para esa página web.

4. Microsoft Authenticator

La aplicación oficial de Microsoft para teléfonos móviles.

Cómo funciona: Al poner tu contraseña, la app te envía una notificación push al móvil. Usualmente te pide "coincidencia de números" (escribir en el móvil el número que ves en la pantalla del ordenador) o simplemente aprobar con tu huella/rostro.

5. OTP por Teléfono / SMS

Código de un solo uso enviado por mensaje de texto o llamada de voz.

Cómo funciona: Tras introducir tu contraseña, el sistema te envía un SMS con un código de 6 dígitos que expira en pocos minutos. Lo introduces en la pantalla para pasar. Es cómodo, pero hoy en día es el método de MFA menos seguro porque los SMS pueden ser interceptados (clonación de SIM).



6. Claves de paso (Passkeys)

La evolución moderna que busca eliminar las contraseñas para siempre.

Cómo funciona: Vincula tu cuenta directamente a la biometría de tu teléfono o PC (FaceID, huella). Para iniciar sesión, solo desbloqueas tu dispositivo habitual.

Internamente funciona con la misma tecnología ultra segura de FIDO2.

7. Token de hardware OATH (Llaveros TOTP)

Un pequeño dispositivo físico (parecido a un llavero) con una pantalla digital.

Cómo funciona: El dispositivo genera un código numérico de 6 dígitos que cambia automáticamente cada 30 segundos de forma desconectada. Lo miras, lo escribes en la pantalla y accedes. Es ideal para empleados que no pueden o no quieren usar su móvil personal.

8. Token de software OATH (Apps de terceros)

El uso de aplicaciones de autenticación que no son de Microsoft (ej. Google Authenticator, Authy, Bitwarden).

Cómo funciona: Al igual que el llavero físico, la app genera códigos de 6 dígitos que cambian cada 30 segundos. A diferencia de la app de Microsoft, estas no permiten notificaciones de "aprobar/denegar" con un toque; siempre debes copiar y pegar el número manualmente.

9. Preguntas de seguridad

El método clásico de recuperación basado en datos personales (ej. "¿Cuál fue tu primera mascota?").

Cómo funciona: Microsoft Entra ID solo las permite para el autoservicio de restablecimiento de contraseña (SSPR), nunca como un factor de MFA para el día a día, ya que son fáciles de adivinar mediante ingeniería social.

MICROSOFT ENTRA ID

METODOS DE AUTENTICACIÓN



PASSWORD



MICROSOFT AUTHENTICATOR



**AUTENTICACIÓN BASADA EN
CERTIFICADO**



OTP POR TELEFONO / SMS



CLAVE DE SEGURIDAD FIDO2





¿Qué es el Acceso Condicional?

El Acceso Condicional es una herramienta de seguridad que actúa como un "portero inteligente". En lugar de darte acceso ciego solo por meter bien tu contraseña y el MFA, analiza el contexto de tu conexión en tiempo real y decide si te deja entrar, si te pide más pruebas o si te bloquea. Su filosofía es: "Confía, pero verifica las condiciones".

¿Cómo funciona?

Funciona mediante una lógica simple de "Si pasa X, entonces haz Y". El sistema evalúa varias señales antes de conceder el acceso:

- Usuario/Grupo: ¿Quién intenta entrar? (Ej: Un administrador tiene más restricciones que un empleado común).*
- Ubicación: ¿Desde dónde se conecta? (Ej: Si te conectas desde Chile y 5 minutos después desde China, bloquea el acceso por ser imposible).*
- Dispositivo: ¿El equipo está autorizado? (Ej: Permite el acceso si es el ordenador de la empresa, pero deniégalo si es un teléfono personal desconocido).*
- Aplicación: ¿A qué intenta acceder? (Ej: Para ver el menú de la cafetería no pide nada; para ver las cuentas bancarias de la empresa exige MFA).*

El resultado de la evaluación:

Tras analizar estas señales, el sistema toma una decisión automática:

- 1. Permitir el acceso directo (todo se ve seguro).*
- 2. Exigir MFA (hay una sospecha leve, como una red Wi-Fi nueva).*
- 3. Bloquear el acceso por completo (amenaza clara o incumplimiento de normas).*



- *Impone políticas de acceso basadas en condiciones.*
- *Las decisiones se toman en tiempo real basadas en el usuario, dispositivo, ubicación, aplicación y riesgo.*



EDICIÓN	CARACTERISTICAS CLAVE
<i>Gratuita</i>	<i>Gestión de usuarios y grupos, SSO básico, MFA.</i>
<i>P1</i>	<i>Todo lo gratuito + Acceso Condicional, SSO ilimitado, Grupos dinámicos, Autoreset de contraseña (SSPR) y Sincronización híbrida.</i>
<i>P2</i>	<i>Todo lo de P1 + Protección basada en Riesgo (IA), Gestión de Identidades Privilegiadas (PIM) y Revisiones de acceso automáticas.</i>
<i>Identidad Externa (para clientes)</i>	<i>CIAM (para clientes), Colaboración B2B, Primeros 50,000 usuarios mensuales activos gratis.</i>





 Entrra

 Microsoft Entra ID

 Entrra



Señales de riesgo
(IP sospechosas,
credenciales filtradas)

- Detecta riesgos de inicio de sesión midiendo anomalías en tiempo real (como ubicaciones de viaje imposibles).
- Monitorea la Dark Web de forma proactiva para reaccionar si las credenciales de un usuario se han filtrado.



Nivel de riesgo
(Bajo, Medio, Alto)
Conditional
Access



Acción

- Requerir MFA
 - Bloquear
 - Forzar cambio de contraseña
- Aplica políticas automáticas basadas en el nivel de riesgo calculando si es Bajo, Medio o Alto.
 - Integración profunda con señales de seguridad locales, de la nube y telemetría global de Microsoft.



¿Qué es PIM?

PIM (Privileged Identity Management o Gestión de Identidades Privilegiadas) es una herramienta de seguridad (exclusiva de la licencia Entra ID P2) que sirve para controlar, monitorear y proteger el acceso a los recursos más importantes de tu empresa (como roles de Administrador Global en Entra ID o roles de Propietario en Azure).

Su filosofía es eliminar los privilegios permanentes: "Nadie debe tener superpoderes todo el tiempo".

¿Cómo funciona?

En lugar de tener usuarios asignados como administradores de forma fija (24/7), PIM introduce el concepto de Acceso Justo a Tiempo (Just-In-Time o JIT).

El flujo funciona así:

- Paso 1: Eres "Elegible", no administrador. Tu usuario no tiene permisos en su día a día. Está en una lista de personas "autorizadas a pedir" el rol cuando lo necesiten.*
- Paso 2: Activación bajo demanda. Cuando necesitas hacer una tarea de administración, entras a PIM y solicitas "activar" el rol.*
- Paso 3: Cumplir las condiciones. Para activar el rol, el sistema te exige justificar la razón, pasar por un control de MFA obligatorio y, si está configurado, esperar a que un jefe o responsable apruebe la solicitud.*
- Paso 4: Tiempo limitado. Una vez aprobado, se te concede el rol solo por unas horas (ej: 2 horas). Pasado ese tiempo, PIM te quita los permisos automáticamente.*

Beneficios clave

- Reduce la superficie de ataque: Si hackean la cuenta de un administrador por la noche, no podrán romper nada porque a esa hora la cuenta no tiene privilegios activos.*
- Historial de auditoría: Queda registrado exactamente quién activó un rol, para qué tarea y quién lo aprobó.*
- Alertas: Avisa al equipo de seguridad cuando se activan roles ultra críticos.*

MICROSOFT ENTRA ID

GESTIÓN DE IDENTIDADES PRIVILEGIADAS (PIM)





¿Qué es la Gobernanza de Identidad?

Microsoft Entra ID Governance es el conjunto de herramientas que asegura que las personas adecuadas tengan el acceso adecuado a los recursos adecuados, y solo durante el tiempo necesario.

Mientras que la seguridad tradicional se enfoca en bloquear la entrada a los hackers, la gobernanza se enfoca en organizar y auditar el desorden interno de permisos de los empleados y colaboradores.

Su filosofía es: "Automatizar el ciclo de vida del acceso y evitar la acumulación peligrosa de permisos".

¿Cómo funciona? (Los 3 Pilares)

Se gestiona principalmente a través de tres componentes automatizados (disponibles como complemento o en licenciamiento avanzado):

1. Gestión del Ciclo de Vida (Lifecycle Workflows)

¿Qué hace? Automatiza qué pasa con la cuenta de un usuario cuando entra, se mueve de puesto o se va de la empresa.

El proceso:

- Si entra un empleado nuevo: El sistema le crea la cuenta y le asigna sus grupos y accesos el día uno automáticamente.*
- Si el empleado renuncia: El sistema bloquea su cuenta, lo saca de todos los grupos y revoca sus accesos de inmediato para que no queden "cuentas fantasma".*

2. Administración de Derechos (Entitlement Management)

¿Qué hace? Agrupa recursos (sitios de SharePoint, apps, grupos) en "Paquetes de Acceso" para que los usuarios puedan pedirlos mediante un portal de autoservicio.

El proceso: Un desarrollador necesita acceso a un proyecto. Va al portal, solicita el "Paquete Proyecto X", el sistema le pide aprobación a su jefe y, al ser aprobado, le da los permisos con una fecha de caducidad automática (ej: el acceso expira en 3 meses).

3. Revisiones de Acceso (Access Reviews)

¿Qué hace? Obliga a los jefes o dueños de los recursos a revisar periódicamente quién sigue teniendo acceso a sus carpetas o aplicaciones.

El proceso: Cada 6 meses, el sistema le envía un correo automático al Director de Finanzas diciendo: "Aquí está la lista de las 50 personas que ven la contabilidad. Confirma quién aún lo necesita". Si el director no marca a alguien, el sistema le quita el acceso automáticamente para mantener la seguridad limpia.

MICROSOFT ENTRA ID

GOBERNANZA DE IDENTIDAD GESTIÓN DEL CICLO DE VIDA



¿Qué es el aprovisionamiento de Identidades?

Es la automatización para crear, mantener y eliminar cuentas de usuarios en los sistemas de la empresa. Su meta es eliminar el trabajo manual de TI cuando alguien entra o sale.

El Ciclo JML (Joiner, Mover, Leaver)

Entra ID gestiona las tres etapas del empleado de forma automática conectado al sistema de RR.HH.:

- *Entrada (Joiner): RR.HH. contrata > Entra ID crea la cuenta, asigna correo, licencias y grupos el día uno.*
- *Cambio (Mover): El usuario cambia de puesto > El sistema le quita los accesos viejos y le da los nuevos de forma automática.*
- *Salida (Leaver): El empleado se va > Se bloquea la cuenta al instante en Entra ID y en todas las aplicaciones para evitar fugas de información.*

Los 2 Flujos Clave

- *Entrada (Inbound): Trae los datos desde la fuente de origen (Workday, SuccessFactors o Active Directory local) hacia Entra ID.*
- *Salida (Outbound): Replica esa cuenta desde Entra ID hacia apps de terceros (Slack, Salesforce, Zoom) usando el estándar SCIM.*



- *Automatiza la creación de cuentas cuando alguien entra y el bloqueo inmediato cuando renuncia.*

MICROSOFT ENTRA ID

GOBERNANZA DE IDENTIDAD ADMINISTRACIÓN DE DERECHOS



Solicitud del usuario



Paquetes de acceso



***Aprobación con
tiempo limite***

- ***Evita que los usuarios acumulen permisos eternamente prestándoles accesos con fecha de vencimiento.***

MICROSOFT ENTRA ID

GOBERNANZA DE IDENTIDAD REVISIONES DE ACCESO



***Auditoría
programada***



***Validación del líder
Access***



***Limpieza automática
Mantener o Revocar***

- *Obliga a los dueños de los datos a certificar de forma periódica quién sigue necesitando acceso.*

MICROSOFT ENTRA ID ROLES AVANZADOS Y DELEGACIÓN



1. Roles Avanzados vs. Roles Estándar

Roles Estándar: Son los roles integrados por defecto (como Administrador Global o Administrador de Usuarios). Tienen permisos fijos y masivos sobre todo el tenant.

Roles Avanzados (Personalizados): Permiten aplicar el Principio de Mínimo Privilegio. Tú creas el rol desde cero combinando únicamente los permisos exactos que necesitas (ej: un rol que solo pueda restablecer contraseñas de usuarios, pero no crearlos ni borrarlos).

2. Unidades Administrativas (AU)

Es la herramienta clave para la delegación regional o departamental. Funciona como un "contenedor" o una sucursal virtual dentro de tu único Tenant.

Cómo funciona: Si tu empresa opera en Chile y España, creas una Unidad Administrativa llamada "Sede Chile" y metes ahí solo a los usuarios y dispositivos de ese país. Luego, asignas a un empleado el rol de Administrador de Usuarios restringido solo a esa Unidad.

El resultado: El administrador de Chile puede gestionar a sus empleados locales, pero no tiene ningún poder sobre los usuarios de España.

3. Delegación segura: El flujo de trabajo

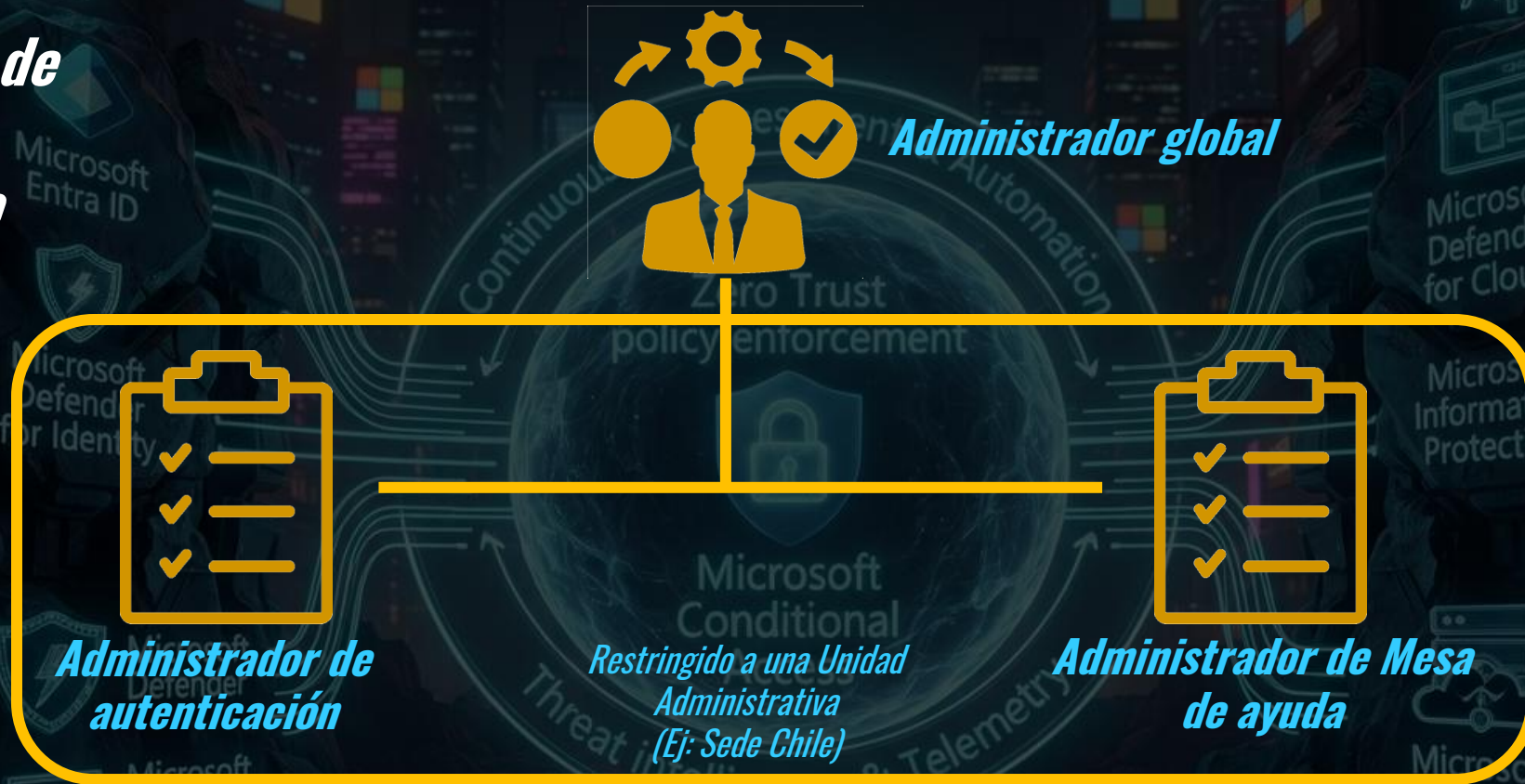
Para delegar con éxito sin comprometer la seguridad, se combinan tres tecnologías:

- **Paso 1 (Delimitar el alcance):** Usas una Unidad Administrativa para que el administrador delegado solo vea su departamento.
- **Paso 2 (Permisos exactos):** Asignas un Rol Personalizado con los permisos mínimos necesarios dentro de esa Unidad.
- **Paso 3 (Control del tiempo):** Obligas a que esa asignación se gestione a través de PIM (Privileged Identity Management), exigiendo que el administrador tenga que activar su rol bajo demanda solo cuando vaya a trabajar.

MICROSOFT ENTRA ID ROLES AVANZADOS Y DELEGACIÓN



Jerarquía de Roles ejemplo



- *Creación de roles personalizados para asignar los permisos mínimos exactos.*
- *Unidades Administrativas (AU) que permiten segmentar el directorio (por región o departamento) para delegar de forma segura.*
- *Control Justo a Tiempo (JIT): Integración con PIM para que estos roles avanzados solo se activen temporalmente bajo demanda y con MFA.*
(Cambiando el error de RBAC por este beneficio real).

MICROSOFT ENTRA ID MONITOREO Y LOGS DE AUDITORÍA



1. Los 2 tipos de Logs principales

Entra ID divide su historial en dos grandes bitácoras:

- **Logs de Auditoría (Audit Logs):**

Registran qué pasó a nivel de configuración. Cada vez que alguien crea un usuario, cambia una contraseña, modifica un grupo o edita una política de Acceso Condicional, queda guardado aquí. Responde al: ¿Quién hizo qué y cuándo?

- **Logs de inicios de sesión (Sign-in Logs):**

Registran cómo y dónde se conectan los usuarios. Almacenan si el inicio de sesión fue exitoso o fallido, qué aplicación usaron, la dirección IP, el país, el dispositivo y si pasaron o no el MFA.

2. Monitoreo avanzado y alertas

Para no tener que revisar millones de líneas de texto de forma manual, el sistema ofrece herramientas de análisis en tiempo real:

- **Análisis de comportamiento:** El motor de IA procesa estos logs para buscar anomalías (como inicios de sesión desde navegadores sospechosos o ubicaciones inusuales).

- **Integración SIEM (Microsoft Sentinel / Log Analytics):** Los logs se pueden exportar automáticamente a centros de monitoreo centralizados. Esto permite programar alertas automáticas (ej: si hay 20 intentos fallidos de contraseña en menos de un minuto para un mismo usuario, el sistema avisa de inmediato al equipo de seguridad por un ataque de fuerza bruta).

3. Retención de datos: El gran detalle

Un administrador debe saber cuánto tiempo sobreviven estos registros por defecto, ya que varía según tu licencia:

- **Licencia Gratuita:** Guarda los logs por solo 7 días.
- **Licencia P1 o P2:** Extiende la retención hasta 30 días.

Nota de arquitectura: Como 30 días suele ser insuficiente para normativas legales o auditorías forenses, la mejor práctica recomendada es configurar el envío de estos logs hacia una cuenta de almacenamiento (Azure Storage) o un espacio de trabajo de Log Analytics, donde puedes guardarlos por meses o años de forma económica.

MICROSOFT ENTRA ID MONITOREO Y LOGS DE AUDITORÍA



Logs de inicio de sesión



Logs de Auditoría



***Integración SIEM
(Microsoft Sentinel)***

- *Visibilidad completa de la actividad de los usuarios.*
- *Logs detallados de inicio de sesión y auditoría.*
- *Integración con herramientas SIEM / SOAR.*

Endpoints



Mobile Device



Microsoft Defender



Microsoft Endpoint Manager

Microsoft Conditional Access



Microsoft Defender Cloud

Microsoft Information Protection



Microsoft Information Protection

Infrastructure



Microsoft Cloud App Security



Network



Seguridad de aplicaciones en Microsoft Entra ID

Cómo proteger y controlar el software que se integra con tu proveedor de identidad corporativo.

1. Registro de aplicaciones vs. Aplicaciones empresariales

En Entra ID, la seguridad de las aplicaciones se divide en dos conceptos clave que debes dominar:

- **Registro de aplicaciones (App Registrations):**

Es la perspectiva del desarrollador. Es donde registras tu propio código para decirle a Entra ID: "Quiero que esta app use tus servicios de autenticación".

Aquí se configuran los permisos de API (como Microsoft Graph) y los secretos/certificados que la app necesita para hablar con Azure.

- **Aplicaciones empresariales (Enterprise Applications):**

Es la perspectiva del administrador de TI. Es el software que ya está listo (ej: Salesforce, Zoom o tus propias apps registradas) y que usas en el día a día. Desde aquí controlas quién dentro de tu empresa tiene permiso para usar esa app específica.

2. Los 3 pilares para proteger las aplicaciones

Para asegurar que ninguna aplicación se convierta en una puerta trasera para los hackers, se aplican tres controles estrictos:

A. Consentimiento de permisos (Consent Framework)

Controla a qué datos de tu empresa puede acceder una aplicación (ej: leer el correo de los usuarios o ver sus perfiles). La regla de oro: Por defecto, se debe bloquear el consentimiento de usuarios. Si una app pide leer datos de la empresa, un Administrador Global debe revisar y aprobar ese permiso (Admin Consent) antes de que nadie pueda usarla, evitando malware camuflado de aplicación inofensiva.

B. Control de acceso (Acceso condicional y asignación)

Asignación obligatoria: Puedes configurar una app para que solo los usuarios explícitamente autorizados o miembros de un grupo específico puedan iniciar sesión en ella.

Políticas a medida: Puedes crear una regla de Acceso Condicional que diga: "Si van a entrar a la aplicación de Finanzas, exige MFA obligatorio y que el dispositivo sea corporativo".

C. Credenciales seguras de la aplicación

Cuando tu código se comunica con Entra ID, necesita demostrar quién es. El uso de Contraseñas de aplicación (Client Secrets) tradicionales es peligroso porque los desarrolladores suelen olvidarlas en el código de GitHub.

La mejor práctica: Usar Certificados digitales o, idealmente, Identidades Administradas (Managed Identities), eliminando por completo las contraseñas del código.



SEGURIDAD DE APLICACIONES EN MICROSOFT ENTRA ID

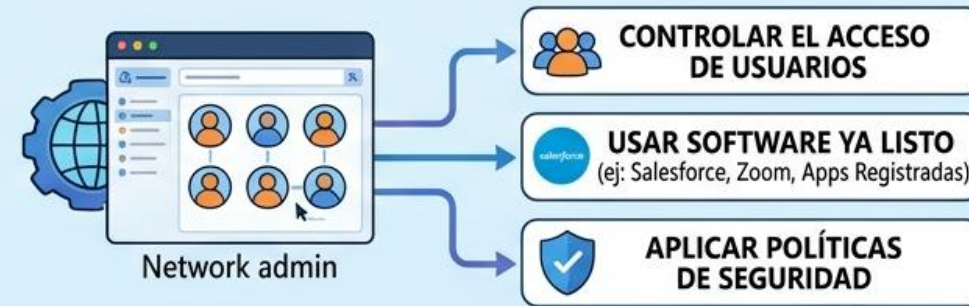
1. REGISTRO DE APLICACIONES

(Perspectiva del Desarrollador)



1. APLICACIONES EMPRESARIALES

(Perspectiva del Administrador de TI)



2. LOS 3 PILARES PARA PROTEGER LAS APLICACIONES

A. CONSENTIMIENTO DE PERMISOS (Consent Framework)



B. CONTROL DE ACCESO (Acceso Condicional y Asignación)



C. CREDENCIALES SEGURAS DE LA APLICACIÓN





Gobernanza de grupos y aplicaciones

Es un framework de seguridad y cumplimiento que evita la acumulación de accesos obsoletos (Privilege Creep) y asegura que solo las personas correctas tengan acceso a los recursos y apps críticas de la empresa.

1. Revisiones de acceso (Access reviews)

Automatiza la auditoría continua para verificar si los usuarios realmente siguen necesitando sus permisos.

- *Decisión delegada: En lugar de saturar a TI, el sistema le pregunta directamente a los líderes de equipo o dueños de la aplicación si aprueban o remueven el acceso de un usuario.*
- *Auto-remediación: Si un revisor deniega el acceso (o no responde en el tiempo límite), Entra ID quita al usuario del grupo o de la aplicación de forma automática.*

2. Gestión de Entitlements (Paquetes de Acceso)

En lugar de asignar grupos uno por uno, se agrupan los recursos por roles.

- *Paquetes de recursos: Un solo "paquete de acceso" puede incluir la membresía a 3 grupos de Teams, accesos a Salesforce y licenciamiento de software.*
- *Ciclo de vida con expiración: Los usuarios (o invitados externos) solicitan el paquete mediante un portal de autoservicio, requiere aprobación y expira automáticamente tras una fecha límite (ej. 6 meses).*

3. Gobernanza de aplicaciones (App Governance)

Control estricto sobre el software y los permisos que tocan los datos de la empresa.

- *Consentimiento del administrador: Bloquea que los usuarios comunes instalen aplicaciones integradas con Entra ID que soliciten leer datos sensibles corporativos.*
- *Ciclo de credenciales y dueños: Monitorea la expiración de secretos/certificados de las aplicaciones y asegura que cada registro de app en Entra ID tenga siempre un dueño activo asignado.*



- *Políticas de caducidad para Grupos.*
- *Propietarios de grupos administrados.*
- *Revisiones de acceso específicas para aplicaciones.*

Endpoints



Mobile Device

Microsoft Entra ID

Microsoft Defender for Identity



Microsoft Defender



Microsoft Endpoint Manager

Zero Trust policy enforcement



Microsoft Conditional Access

Threat intelligence & Telemetry

Microsoft Defender for Cloud

Microsoft Information Protection



Microsoft Information Protection

Infrastructure



Microsoft Cloud App Security



Network

Application



Gestión de dispositivos en Entra ID

Es el control y registro de todos los equipos (Laptops, Móviles, Tablets) que intentan acceder a los datos de la empresa. Su objetivo es asegurar que solo los dispositivos autorizados y seguros puedan conectarse.

El Rol de la identidad del dispositivo

Así como un usuario tiene un usuario y contraseña, el dispositivo también necesita una identidad digital en la nube. Entra ID la gestiona a través de tres estados:

- ***Entra ID Registered (Registrado):*** Para dispositivos personales (BYOD). Permite Single Sign-On (SSO) a las apps de la empresa sin que la compañía tome el control total del equipo.
- ***Entra ID Joined (Unido a la nube):*** Para equipos propiedad de la empresa. Se gestionan 100% desde la nube, ideal para trabajadores remotos sin

infraestructura local.

- ***Hybrid Entra ID Joined (Híbrido):*** Para empresas con infraestructura tradicional. El equipo está unido al Active Directory local de la oficina y sincronizado simultáneamente con la nube.

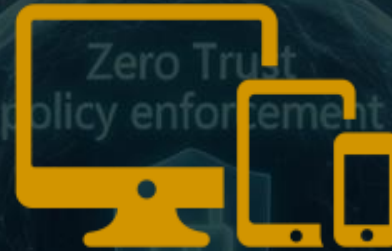
El candado clave: Acceso condicional e Intune

La gestión de dispositivos no trabaja sola; es el puente hacia el modelo Zero Trust:

- ***Validación de cumplimiento (Compliance):*** Microsoft Intune evalúa si el dispositivo tiene el antivirus activo, el disco cifrado (BitLocker) y el sistema operativo actualizado.
- ***Bloqueo automático:*** Si el dispositivo cumple, Entra ID le abre la puerta. Si está "No Compliant" (ej. tiene el antivirus desactivado), el Acceso Condicional le bloquea la entrada a los datos de la empresa, incluso si el usuario introdujo su contraseña y MFA correctamente.



***Unión a Microsoft
Entra (Azure AD Join)***



***Registro de
dispositivos***



***Cumplimiento de
políticas (con Intune)***

- *Inscripción de dispositivos (Join, Register).*
- *Integración con Microsoft Intune para cumplimiento.*
- *Control de acceso basado en el dispositivo.*



Microsoft
Entra ID

Entra ID



✓ *Gestión de Identidad centralizada.*

✓ *Acceso seguro con Acceso Condicional y MFA.*

✓ *Inicio de Sesión Único (SSO) para aplicaciones en la nube y locales.*

✓ *Protege identidades y reduce riesgos.*

✓ *Escalable y costo efectivo.*



TERMINO	EXPLICACIÓN
Tenant	<i>Una instancia dedicada de Entra ID.</i>
Registro de aplicaciones	<i>Registrar una aplicación para integrarla con Entra ID.</i>
Aplicación empresarial	<i>Aplicación preconfigurada para SSO y asignación de usuarios.</i>
ID de objeto	<i>Identificador único para usuarios, grupos, aplicaciones, dispositivos.</i>
Rol de Directorio	<i>Roles asignados para gestionar recursos de Entra ID.</i>
PIM	<i>Gestión de Identidades Privilegiadas.</i>
Access Reviews	<i>Revisiones de acceso.</i>
JIT	<i>Acceso Just in Time.</i>
Identity Protection	<i>Protección de Identidad.</i>
SIEM	<i>Gestión de Información y Eventos de Seguridad.</i>



VALLEY OF MICROSOFT ENTRA ID

